



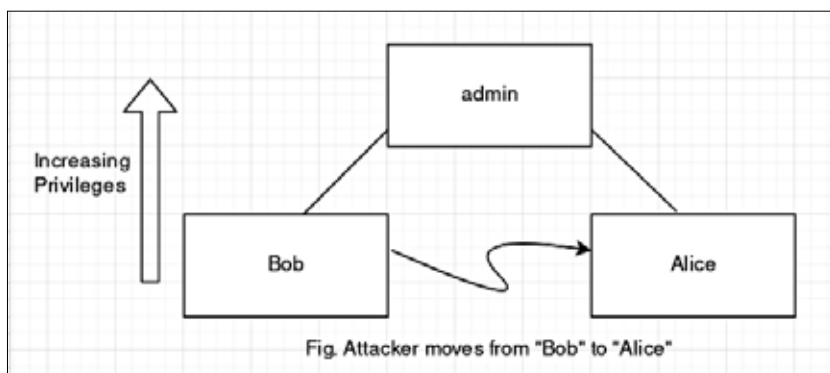
LG Replace CEO

LG CEO Jo Seong-jin has been replaced after struggling to turn the failing smartphone division around. <https://dgit.in/dec19-45>



Lenovo tease upcoming 5G chip

Lenovo took to Chinese social network Weibo to tease their upcoming 5G processor. <https://dgit.in/dec19-46>



The categorization we talked about was mainly from a theoretical point of view, but security is most parts technical and hence finer divisions are necessary to understand privilege escalation and mitigation. Technically, escalation attacks can be distinguished based on the operating system of the machine under attack and the two most widespread OS are Unix/Linux and MS Windows, hence we'll focus on these two. (Privilege escalation attacks do exist for Mac systems, we'll talk about them later in a brief manner).

COMMONLY TARGETED OS

Unix/Linux and MS Windows makes up to about 99.8% of the OS being used in the wild on the world wide web. Who uses Mac OS as backend server OS anyway, right? Pfft. But apparently, some machines have been seen running Apple's home grown OS. Most websites you see are on Unix/Linux based servers while Windows provides support to Remote Procedure Calls(facility for remote interaction to systems not available for physical access), file sharing services, etc.

Unix/Linux Privilege Escalation Attacks:

Almost 70% of the websites use Unix/Linux based OS, as of 14th November 2019 (<https://dgit.in/osoverview>), as a result, an array of privilege escalation attacks exist for these systems. Firstly, we'll be broad with the categorisations and then check out the finer details under these categories:

• System misconfigurations:

System admins are after all humans, and

many a time while managing complex systems some configuration done to minimize efforts/work may prove fatal to the security of the system. While doing machines on the HackTheBox platform (<https://dgit.in/htb>), the most basic step is to check what commands are allowed by the system to be run as sudo, by running `sudo -l`. Now, this is an intended feature of sudo but provides crucial information to the attacker. One of our favorite use of this command was in OneTwoSeven machine which revealed that the `http_proxy` environment variable was being used while running `apt-get update` using a proxy server as sudo, which allowed us to perform a man-in-the-middle(MITM) attack (<https://dgit.in/mitm>). Misconfigurations can sometimes be easy to exploit, sometimes extremely hard, all varying from system to system. Another misconfiguration we have encountered many times is giving read/write access rights to files without considering their future consequences. For example, consider a seemingly benign file that anyone can read/edit, this file, in turn, gets used by another file/process during run-time, which gets executed through higher privileges. Editing the base file (with fewer restrictions) with a payload that can lead to privilege escalation.

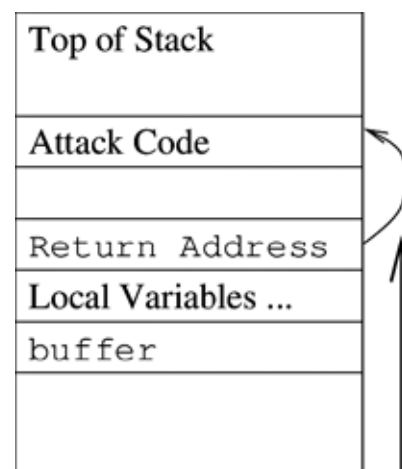
• Binary exploits:

Many servers/systems use custom binaries to run specific services, which the system owner or service provider has developed in house. These binaries are written in low-languages to improve performance and C/C++ is the language of choice. But the problem is that C/C++

are neither memory-safe nor type-safe or simply put, they are susceptible to buffer-overflow attacks. Buffer-overflow attacks is a huge topic by itself and are out of the scope of this article. Even if the binaries are not custom-built, the Unix/Linux system binaries may pose a threat to the system's security. GTFOBins (<https://dgit.in/gtfobins>) is a highly curated list of exploits in system binaries that may help in bypassing local restrictions and is one of the best places to get the required payloads for binary exploitations.(These are not necessarily classic attacks like buffer-overflow, ret2libc attack, etc).

• Rootkits:

These are a special kind of tools which are usually built to exploit programs which work at the kernel level, for example, hardware drivers, etc. These are harder to create since knowledge of machine language is required and hence is one of the areas where we continu-



ously try to improve our skills. We only encountered one machine where we needed a rootkit to gain root privileges where a backdoored kernel object (compiled from a Linux kernel module) was used to gain root access. Here's a great article that helped a lot: <https://dgit.in/kernelrootkit>.

• Insecure Credentials:

Sometimes, the applications you put your trust into might not be worthy of it. A lot of applications, over the years,